Assets

Assets is a read-only file service on `https://assets.kanthorlabs.com`.
One Cloudflare Worker serves public assets and private links from one private
Cloudflare R2 bucket.

Source: https://github.com/kanthorlabs/assets

Routes

The Worker accepts `GET` and `HEAD` only. For another method it returns `405`,
and for an unknown path `404`. In production, a zone rule blocks both cases
with a Cloudflare `403` before the Worker.

Route	Response
`/`	This README as plain text.
`/ip`	The client IP address.
`/a/<path>.<ext>`	A public asset from the R2 key `a/<path>.<ext>`.
`/f/<uuid>/<basename>`	A private file from the R2 key `f/<uuid>/<basename>`.

`/ip` returns plain text. If the `Accept` header contains `application/json`,
`/ip` returns `{"ip":"<ip>"}`.

```sh
curl https://assets.kanthorlabs.com/
curl https://assets.kanthorlabs.com/ip
curl -H 'Accept: application/json' https://assets.kanthorlabs.com/ip
curl -O https://assets.kanthorlabs.com/a/<path>.<ext>
curl -O https://assets.kanthorlabs.com/f/<uuid>/<basename>
```

`<uuid>` is a lowercase UUIDv4. The unguessable UUID protects a forward link.
The [HTTP API](docs/reference/api.md) gives the validation rules, status codes
and headers.

Features

- Single byte range requests return `206` on `/a/` and `/f/`.
- A weak `If-None-Match` match returns `304`. Cloudflare removes `ETag` from
  HTML responses, so HTML gets no `304`.
- `HEAD` returns the same status and headers as `GET`, with no body.
- HTML and SVG responses carry a `Content-Security-Policy` sandbox.
- The service only reads. Uploads follow the
  [upload contract](docs/reference/upload-contract.md) in a separate workspace.
- Workers Free is the hard cost cap. Each request makes at most one R2 call.
  The one exception is an unsatisfiable range, which makes two R2 calls.

Quick start

Requirements:

- Node 24.15.0
- pnpm 11.24.0

Run these commands from the repository root:

```sh
pnpm install --frozen-lockfile
pnpm run check
```

`pnpm run check` runs typecheck, lint, tests and the production build.
The checks need no Cloudflare account and no credentials.

To run the Worker locally, run this command from `cloudflare/`:

```sh
pnpm run dev
```

The Worker listens on `http://localhost:8787` with a local R2 bucket named
`assets-local`. To put objects in that bucket, follow
[E2E fixtures](cloudflare/e2e-fixtures/README.md#run-the-suite-against-the-local-worker).

Project layout

Path	Content
`core/`	`@kanthorlabs/assets-core`: platform-independent request logic.
`cloudflare/`	`@kanthorlabs/assets-cloudflare`: Worker entry, R2 reader, tooling, tests.
`cloudflare/zone-rules/`	Zone rules: rate limit, method and path allowlist, kill switch.
`docs/`	Platform-independent contracts: API, acceptance, upload, security.
`cloudflare/docs/`	Cloudflare operations: deploy, credentials, CI, incident, architecture
.
`.github/workflows/`	CI: checks on each pull request, deploy and live E2E on `main`.

Deploy

CI deploys each push to `main` and then runs the live E2E suite. A manual
deploy runs `pnpm run deploy` from `cloudflare/` with a private
`.env.production` file. The deploy refuses to take over resources that another
deployment owns. For the first deploy, follow
[Deploy to Cloudflare](cloudflare/docs/how-to/deploy.md).

Documentation

The documentation follows the Diátaxis structure (https://diataxis.fr/).

- How-to guides:
  [deploy](cloudflare/docs/how-to/deploy.md),
  [credentials](cloudflare/docs/how-to/credentials.md),
  [CI](cloudflare/docs/how-to/ci.md),
  [incident runbook](cloudflare/docs/how-to/incident.md).
- Reference:
  [HTTP API](docs/reference/api.md),
  [acceptance checks](docs/reference/acceptance.md),
  [upload contract](docs/reference/upload-contract.md),
  [configuration](cloudflare/docs/reference/configuration.md),
  [commands and tooling](cloudflare/docs/reference/tooling.md),
  [E2E fixtures](cloudflare/e2e-fixtures/README.md).
- Explanation:

  [security model](docs/explanation/security.md),
  [architecture and cost cap](cloudflare/docs/explanation/architecture.md).

Security and abuse protection

Report a vulnerability in a private security advisory, not in a public issue.
On GitHub, go to `kanthorlabs/assets`, open the Security tab and select
"Report a vulnerability". Select the matching CWE in the report.

Request controls:

- The Worker accepts `GET` and `HEAD` only.
- Strict validation applies to each path. A forward id must be a lowercase
  UUIDv4.
- The validator rejects traversal, percent-encoded characters, backslash,
  dotfiles and empty segments.
- The Worker ignores the query string.
- Error bodies are plain text with the reason phrase only. They never contain
  exception text.

Response headers:

- Every response has `X-Content-Type-Options: nosniff` and
  `Referrer-Policy: no-referrer`.
- HTML and SVG responses carry a `Content-Security-Policy` sandbox. A PDF never
  gets the sandbox.
- The service sets no cookies.
- `/f/` responses carry `Cache-Control: no-store`.
- Only `/a/` responses carry `Access-Control-Allow-Origin: *`.

Edge controls (zone rules in `cloudflare/zone-rules/`):

- A rate limit blocks an IP for 10 s after 50 requests in 10 s on `/`, `/ip`,
  `/a/` and `/f/`.
- A custom rule blocks other methods and other paths.
- A kill switch rule blocks the hostname. It is disabled.
- A configuration rule keeps HTML unchanged.

Cost cap:

- Workers Free is the hard cap: 100,000 requests per day. A flood is an outage
  until 00:00 UTC, not a bill.
- Each request makes at most one R2 call. An unsatisfiable range makes two.
- No R2 S3 credentials exist. The deploy and CI tokens have no R2 permission.
- R2 egress is free.
- The account preflight checks the cost cap conditions. A `$3` budget alert
  reports a charge outside the cost model.
- The worst case is about $1.35 per month, for 100 GB of R2 storage.

See the [security model](docs/explanation/security.md), the
[incident runbook](cloudflare/docs/how-to/incident.md) and the
[upload contract](docs/reference/upload-contract.md).

Contribute

1. Open an issue or a pull request on `kanthorlabs/assets`.
2. Run `pnpm run check` before you push. The command must exit with `0`.

3. Write commit messages in the Conventional Commits format, for example
   `fix: answer 416 on production R2`.

License

MIT. See LICENSE.